

# Protocolo de Actuación ante Incidentes de Seguridad

## — ScholalA / AvisIA

Documento interno. No es un texto legal para publicar; es una guía práctica para que los socios sepan exactamente qué hacer si algo falla. Revisar y actualizar cada vez que cambie la infraestructura o se añadan colegios nuevos.

### 1. ¿Qué se considera un incidente?

Marcar como incidente cualquiera de estos casos (o similares):

- Un colegio ve datos, conversaciones o informes de **otro colegio** (fuga cruzada entre tenants).
- Alguien accede al panel de control sin autorización.
- El bot revela su configuración interna (prompt del sistema) o información que no debía.
- El bot da información falsa o inapropiada de forma repetida a usuarios.
- Caída total o parcial del servicio (el bot no responde).
- Pérdida o corrupción de datos de un colegio.
- Sospecha de acceso externo no autorizado (hackeo) a servidores o base de datos.
- Un proveedor externo (hosting, API de IA) sufre una brecha que os puede afectar.

**Nivel de gravedad** (asignar rápido, no hace falta precisión):

-  **Leve** — afecta a la experiencia pero no a datos personales (ej. bot lento).
-  **Moderado** — afecta a un colegio, sin exposición de datos a terceros.
-  **Grave** — hay datos personales expuestos, mezclados entre colegios, o acceso no autorizado confirmado.

### 2. Roles: quién hace qué

|  |  |  |
|--|--|--|
|  |  |  |
|--|--|--|

| Rol            | Quién                                       | Responsabilidad                                                  |
|----------------|---------------------------------------------|------------------------------------------------------------------|
| Detección      | [Socio/persona encargada de monitorización] | Detecta o recibe el aviso del incidente                          |
| Decisión       | [Socio 1 y/o Socio 2]                       | Clasifica la gravedad y decide los siguientes pasos              |
| Técnico        | [Quién tiene acceso a servidores/paneles]   | Ejecuta la solución técnica (cortar acceso, restaurar, parchear) |
| Comunicación   | [Quién habla con el colegio afectado]       | Redacta y envía el aviso al centro educativo                     |
| Legal/Registro | [Quién documenta todo]                      | Guarda evidencias y redacta el informe final                     |

*(En una empresa de 2 socios, una persona puede cubrir varios roles — lo importante es tenerlo decidido de antemano, no improvisarlo el día del incidente.)*

### 3. Pasos a seguir (en orden)

#### Paso 1 — Contener (primeras 1-2 horas)

- Cortar el acceso o desactivar la función afectada si es necesario (ej. desactivar temporalmente el bot de un colegio si hay fuga de datos).
- No borrar nada todavía — hace falta guardar evidencia de qué pasó.

#### Paso 2 — Evaluar

- ¿Hay datos personales afectados? ¿De cuántas personas aproximadamente? ¿De qué colegio(s)?
- ¿Es un fallo técnico interno o un ataque externo?
- Clasificar gravedad (🟢🟡🔴, ver arriba).

#### Paso 3 — Notificar (si es 🟡 o 🔴)

- **Al colegio afectado:** cuanto antes, con lenguaje claro, explicando qué pasó y qué se está haciendo. Usar la plantilla de la Sección 4.
- **A la Agencia Española de Protección de Datos (AEPD):** obligatorio en **72 horas** si hay

riesgo real para los derechos de las personas afectadas (Art. 33 RGPD). Si tenéis dudas de si aplica, consultar con un abogado/gestoría rápido — mejor notificar de más que de menos.

## Paso 4 — Resolver

- Aplicar la solución técnica definitiva (parchear el fallo, restaurar backup, reforzar permisos, etc.).
- Confirmar que el problema no sigue activo antes de reactivar el servicio.

## Paso 5 — Revisar y documentar

- Escribir qué pasó, por qué, cómo se solucionó y qué se cambia para que no vuelva a pasar (ver plantilla de informe, Sección 5).
- Actualizar este protocolo si se detecta algo que no estaba previsto.

---

## 4. Plantilla de aviso al colegio afectado

Asunto: Aviso de incidencia de seguridad — [Nombre del colegio]

Estimado/a [director/a o responsable],

Le informamos de que el [fecha] hemos detectado [breve descripción del incidente, sin tecnicismos].

Datos afectados: [qué tipo de datos, o "ninguno dato identificativo" si aplica]

Alcance: [cuántas personas/qué periodo aproximado]

Acciones tomadas: [qué habéis hecho ya para contenerlo]

Próximos pasos: [qué vais a hacer y cuándo tendrán más información]

Quedamos a su disposición para cualquier aclaración en [contacto@vuestramarca.es] / [teléfono].

Atentamente,

[Nombre] — ScholaIA / AvisIA

---

## 5. Plantilla de informe interno post-incidente

FECHA DEL INCIDENTE:

FECHA DE DETECCIÓN:

GRAVEDAD (●/●/●):

COLEGIO(S) AFECTADO(S):

¿QUÉ PASÓ?

¿CÓMO SE DETECTÓ?

¿QUÉ DATOS SE VIERON AFECTADOS?

¿SE NOTIFICÓ A LA AEPD? (Sí/No, fecha)

¿SE NOTIFICÓ AL/LOS COLEGIO(S)? (Sí/No, fecha)

CAUSA RAÍZ (por qué pasó realmente):

SOLUCIÓN APLICADA:

CAMBIOS PARA EVITAR QUE SE REPITA:

RESPONSABLE DEL SEGUIMIENTO:

---

## 6. Simulacro recomendado

Antes de vender a más colegios, hacer al menos un simulacro tipo:

“Un director os llama diciendo que en el panel de su colegio ve preguntas y respuestas de otro instituto. ¿Qué hacéis en los primeros 30 minutos?”

Si al responder esta pregunta os quedáis sin saber quién decide, a quién avisáis primero o cómo cortáis el acceso técnicamente — el protocolo aún no está completo. Repetir el ejercicio hasta que la respuesta sea clara y rápida para los dos socios.

---

## **7. Checklist de mínimos técnicos (para que este protocolo tenga sentido)**

- Backups automáticos y periódicos de la base de datos de cada colegio.
- Logs de acceso al panel de control (quién entró, cuándo, desde dónde).
- Aislamiento real de datos entre colegios verificado (no solo "creemos que está bien separado").
- Al menos una persona con acceso técnico de emergencia disponible en todo momento (no depender de una sola persona de vacaciones).
- Este documento guardado en un sitio accesible por ambos socios (no solo en el ordenador de uno).